

The Ethical Hacker's Command Handbook

Chapter 2 – Part 8: Real-World Nmap Workflows & Enumeration Strategy

Build repeatable, structured enumeration workflows for authorized security assessments.

Learning Objectives

Learn structured enumeration, choose the correct Nmap command for each phase, avoid common mistakes, and document findings effectively.

Recommended Enumeration Workflow

1. Host Discovery (-sn)
2. Port Scan (-sS -p-)
3. Service Version Detection (-sV)
4. Operating System Detection (-O)
5. Default NSE Scripts (-sC)
6. Service-Specific NSE Scripts
7. Research and Documentation

Single Host

Command: `sudo nmap -sS -p- -T4`

Discover all TCP ports before performing version detection and NSE enumeration.

Web Server

Command: `sudo nmap --script http-title,http-enum,http-headers`

Gather web server information before researching technologies.

SMB Server

Command: `sudo nmap --script smb-os-discovery,smb-enum-shares,smb-vuln-ms17-010`

Enumerate SMB safely and identify known issues.

SSH Server

Command: `sudo nmap --script ssh-hostkey`

Collect SSH host key information and supported algorithms.

FTP Server

Command: `sudo nmap --script ftp-anon,ftp-syst`

Check anonymous access and identify FTP server details.

UDP Scan

Command: `sudo nmap -sU --top-ports 100`

Start with common UDP ports before attempting larger UDP scans.

Save Results

Command: `sudo nmap -oA initial_scan`

Save normal, XML, and grepable outputs for reporting.

Decision Tree

Host Discovery → Port Scan → Service Detection → OS Detection → Default NSE → Service-Specific NSE → Research → Documentation

Comparison Table

Situation	Recommended Command
Initial TCP Scan	-sS -p-
Version Detection	-sV
OS Detection	-O
Default Scripts	-sC
Web Enumeration	http-* NSE
SMB Enumeration	smb-* NSE
FTP Enumeration	ftp-* NSE
SSH Enumeration	ssh-* NSE
Save Results	-oA

Common Mistakes

- Running -A immediately on every target.
- Skipping service version detection.
- Not saving scan results.
- Using every NSE script without a purpose.
- Failing to research discovered services.

Practice Questions

1. Why is phased enumeration preferred?
2. What follows port discovery?
3. Which workflow is suitable for SMB?
4. Why are UDP scans slower?

5. Why should every scan be documented?